POUR ALLER PLUS LOIN

- La CNIL a publié un **guide RGPD**[56] **spécifiquement à destination des équipes de développement** pour les aider à mettre en conformité leurs développements informatiques avec la règlementation concernant la protection des données personnelles.
- **Mettre en place une défense en profondeur** des systèmes, c'est-à-dire une combinaison de plusieurs mesures de sécurité et contrôles (ex. : contrôler les données entrées dans un formulaire en ligne mais également protéger les requêtes en base de données). En particulier, les mesures en place sur la partie « *front* » d'une application peuvent être contournées et devraient être renforcées par des mesures sur la partie « *back* ».
- Le développement doit imposer des **formats de saisie et d'enregistrement des données qui minimisent les données collectées**. Par exemple, s'il s'agit de collecter uniquement l'année de naissance d'une personne, le champ du formulaire correspondant ne doit pas permettre la saisie du mois et du jour de naissance. Cela peut se traduire notamment par la mise en œuvre d'un menu déroulant limitant les choix pour un champ du formulaire.
- Un article dédié aux zones de texte libre ou de commentaires est accessible sur le site de la CNIL[57].
- Les conventions ou règles de codage et la documentation sont essentielles pour maintenir l'application ou le service dans le temps sans introduire de nouvelles vulnérabilités et pour corriger efficacement les dysfonctionnements.
- Les formats de données doivent être compatibles avec la mise en œuvre de la durée de conservation choisie. Par exemple, si un document numérique doit être conservé 20 ans, il pourrait être pertinent de privilégier des formats ouverts, davantage susceptibles d'être maintenus sur le long terme.
- La **création et la gestion de profils utilisateur** donnant des droits d'accès aux données variant en fonction des catégories d'utilisateurs doivent être intégrées dès la phase de conception.
- Les tests menés sur les données fictives ou anonymisées ne sont parfois pas suffisants pour s'assurer du bon fonctionnement d'un nouveau service ou d'une nouvelle fonctionnalité. Il est alors possible de tester dans un environnement de pré-production avec des données réelles. L'environnement de pré-production doit être configuré et sécurisé au même niveau que l'environnement de production lui-même et le nouveau service ou sa mise à jour doit avoir déjà subi l'ensemble des tests (unitaires, d'intégration et fonctionnels) dans les environnements de développement et de test.
- Selon la nature de l'application, il peut être nécessaire d'assurer son intégrité par le recours à des signatures de code exécutable garantissant qu'il n'a subi aucune altération.

56 « Guide RGPD de l'équipe de développement », lincnil.github.io

57 « Zones bloc note et commentaires : les bons réflexes pour ne pas déraper », cnil.fr